

OWASP ZAP

Security tool for Web application analysis.

What it is

ZAP is an open-source security proxy used to inspect traffic and support Web application testing.

Official site and documentation

Use the official OWASP ZAP source as the primary reference: <https://www.zaproxy.org/download/>. Official documentation should be the first source for installation, supported versions, syntax changes and new features.

Safe use

Start with authorized environments. Passive Scan observes traffic; Active Scan sends attacks and requires explicit authorization.

QA pipelines

ZAP can support automated DAST in controlled environments with false-positive triage criteria.

When to use it

Use this knowledge when product risk, architecture or the delivery stage requires this type of validation. Confirm the goal, environment, required data and expected evidence before starting.

How QA applies it

Start from the behavior or risk to validate, prepare data and environment, execute the technique or tool reproducibly and capture evidence that helps the team understand the result.

Good practices

Prioritize high-impact scenarios, keep data and environments controlled, record important decisions and review the approach periodically to avoid redundant or outdated coverage.

First QA-oriented use

Pick one small, verifiable task in OWASP ZAP, configure only what is necessary, run a simple example and confirm the outcome. Repeat with different data or conditions before adding abstractions.

Using it in a real project

Define where OWASP ZAP fits, who owns configuration, how credentials and data are handled and how results are shared. Integrate it into the team workflow instead of creating an isolated activity.

Adoption good practices

Standardize versions and configuration, document important decisions, keep secrets out of code and preserve reproducible examples. Reassess whether OWASP ZAP still delivers value as the product evolves.

Common issues and troubleshooting

When OWASP ZAP fails, verify versions, dependencies, permissions, connectivity, data and environment before assuming a product defect. Preserve the original error and reduce the issue to the smallest reproducible case.